

# Justifying the exclusions (D8) and the strategy note

## ✓ The document that will face the auditor

### D8 changes readers

#### An internal document

its readers share the context: the unspoken gets through

#### A defensible document

its reader knows only the page: every acronym spelled out, every reference named, every claim proven

## Session objectives

By the end of this lab, the MERIDIAN group's D8 deliverable is produced: the ISMS scope, written and dated, and the Statement of Applicability on the investigated controls, every control traced, every exclusion justified, the coverage rate displayed. The lab lasts 35 minutes after lunch, then the sequence continues as supervised project time, two hours to move the submission file forward. What is also learned there:

- **Draft** a scope grounded in the mapping, interfaces included
- **Read** in the tool the counts of the Statement of Applicability and display its coverage rate honestly

- **Carry** into D8 the register of exclusions entered in the tool in the morning, and recognize the justifications that would not hold before an auditor
- **Enrich** the group's strategy note with its "ISMS scope" subsection, consistent with the seven subsections preceding it

## Prerequisites

- The assessment conducted in the previous lab: the clauses assessed, the fifteen investigated controls marked. D8 assembles, it does not start over.
- The lecture: the justification rules, the linkage with the session 7 treatment plan.
- The session 2 mapping: the scope is written on top of it.
- The group's strategy note in its session 7 state: seven subsections, from context to risk treatment.

## ✓ Deliverable D8: template and requirements

---

D8 is the module's first deliverable an external auditor would read as is: the session 4 audit report was internal, the session 7 register is a steering tool, but the scope and the Statement of Applicability are master pieces of a certification file. Write them as such, and measure what that changes in the tone: an internal document can afford implications, because its readers share the context; a defensible document cannot, because its reader, auditor, client or judge, knows of MERIDIAN only what the page tells them. Every acronym is expanded at its first occurrence, every cross-reference names its target, every statement carries its proof. It is slower to write, and that is exactly why the module has D8 produced in a supervised session rather than as homework.

Here is the template for the submission:

| D8 section                    | Expected content                                                                                                                                                                                                                                                                                                                             | Source                                                                        |
|-------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------|
| 1. ISMS scope                 | Activities and services covered, entities and sites, systems, interfaces with the outside of the perimeter, owned scope exclusions                                                                                                                                                                                                           | Session 2 mapping, scope trade-off discussed in the morning                   |
| 2. Statement of Applicability | The investigated controls, fifteen at least, all 93 if the group goes all the way during supervised time, and the coverage rate, investigated controls out of 93; status, justification for inclusion (register risk or legal or contractual requirement) or exclusion, implementation state, pointer to the control in place or to the plan | Lab assessment, session 7 register and treatment plan, session 4 audit report |
| 3. Register of exclusions     | Each non-applicable control, with its developed justification and its investigation: who confirmed the fact founding the exclusion, and when                                                                                                                                                                                                 | The morning lab, entered in the tool                                          |
| 4. Summary for management     | Ten lines: profile of the initial assessment, designated work sites, expected decision                                                                                                                                                                                                                                                       | Lab sheet                                                                     |

Acceptance criteria for the submission, the ones the evaluator will apply: each exclusion is justified by a verifiable absence of object, never by a cost or a preference; each included control is traced to a risk in the D7 register or to a named legal or contractual requirement; and the scope described in section 1 is consistent with the session 2 mapping, same business assets, same supporting assets, same interfaces, with no object invented or forgotten. The coverage rate, finally, is displayed at the head of section 2, and the controls not yet investigated are listed as such, never counted as compliant.

## ✓ Step 1: writing the scope (10 minutes)

1. **Draft** section 1 of D8 in half a page structured in four paragraphs: the activities covered, starting from the business assets of the subsidiary under review mapped in session 2; the entities and systems, starting from the supporting assets; the interfaces, those listed in §6 of the subsidiary pack, with the mechanism that controls them or its absence; and the scope exclusions, that is, what the ISMS does not cover yet, named honestly.
2. **Check** the writing against the third-party test: would a person outside the group, reading this half page alone, be able to say whether a given system is in or out? Every sentence that fails this test gets rewritten.

## Step 2: reading the counts in the tool (5 minutes)

Nothing is copied by hand: the tool counts the results by status and displays the assessment's progress. The morning's lab investigated fifteen controls at least; the 78 others are not required for D8, they are marked during supervised project time, and the coverage rate says honestly where the statement stands. The register of exclusions, section 3 of D8, has been in the tool since the morning; D8 carries it over as is.

1. **Record** from the tool the Annex A counts: investigated controls, results by status, coverage rate out of 93, and carry them into section 2 of D8. The traceability line of each investigated control is its observation in the tool; D8 cites it, it does not rewrite it. For the record, the expected level of an observation: the inventory of information and other associated assets control, applicable, justified by the requirement to know the information system and traced to the session 2 mapping, state partial, proof: the supporting assets entered in the tool and the holes noted in session 2.
2. **Check** the cross-consistency in the tool: each applied control of the treatment plan is linked there to its register scenarios and to its Annex A requirements. Each risk in the D7 register whose treatment is "reduce" must lead to at least one included control; each major deviation of the session 4 audit report to an included control that is noncompliant or partial. The tool shows the links, it does not do the check: note on the sheet any orphan discovered.

### Risk register

every risk treated as "reduce"



### At least one included control

that treats this risk

### Audit report

every major gap found



**An included control,  
noncompliant or partial**  
that carries this gap

any orphan, in either direction, gets noted and investigated

## Step 3: reading what the assessment tells, and the summary for management (5 minutes)

---

The figures produced this morning tell a story, and it will have to be told at the defence. This is step 4 of the morning lab, moved here to give it its place.

1. **Compare** the profile of the clauses: which hold thanks to the work of the past eight weeks, which remain bare? If the assessment is honest, context and planning come out better than support and performance measurement: the module built in that order, and session 9 exists to fill what remains.
2. **Write** section 4 of D8, the ten-line summary for management: the profile of the initial assessment, the coverage rate, the two weakest clauses, the designated work site, the expected decision.

## Strategy note (15 minutes)

---

The module's ritual quarter hour: the group's strategy note gains its eighth subsection, "ISMS scope". Half a page at most, and nothing that precedes gets rewritten: the seven existing subsections, from the session 1 context to the session 7 risk treatment, stay as they are, amendable by one justified sentence if the day's exercise contradicts them.

What the subsection contains: the chosen scope, in two sentences, with the owned choice of the initial perimeter and its targeted extension; the recommended certification decision, the one from the morning's case, with its interim answer to the third party; and the finding of the initial assessment, in one honest sentence, the profile stating road traveled and remaining work sites. The linkage with the existing text is the criterion that weighs: the session 2 "critical assets" subsection justifies the chosen scope, to be cited; the session 7 "treatment and residual risk" subsection founds the Statement of Applicability, to be said in one sentence; that is the linkage the oral defense will test. The document's constraints remain: three to five pages of text for the whole, tables and appendices not counted, nothing gets deleted, and the exercise weighs 10 points in the module's grading scale.

And to close the session, the sentence that hands it on: the group's ISMS now has a written scope, a justified Statement of Applicability and an initial assessment that designates its two work sites, documents and measurement; session 9 opens exactly there, keeping the system alive through its policy, its documentary corpus and its indicators, and the strategy note will receive its final subsection there.

## ✓ Supervised project time (120 minutes)

---

The day ends with two hours of work in the room, the teacher remaining available to play the Chief Financial Officer or the Chief Executive Officer on request. This time replaces the session's second tutorial and part of its labs: it serves the submission file, the one the defence rests on, and it has an order of priority.

1. **Finish** D8: reread the summary for management, the register of exclusions against the auditor's test, the coverage rate at the head of the statement.
2. **Reread** the strategy note from end to end, subsections 1 to 8, so that it reads as a single document: same scope, same figures, same decisions from one subsection to the next.
3. **File** the submission by session: in each, the written CISO's desk of every group member and deliverables D1 to D8, in the form the group has chosen.
4. **Extend** the Statement of Applicability to the 78 remaining controls, for groups that want the complete statement: it is the most useful use of the remaining time, not an obligation.
5. **Ask** the Chief Financial Officer or the Chief Executive Officer the questions the file leaves open, rather than inventing the answer.

What remains for session 9: deliverable D9, the ninth subsection of the note and the presentation support, which is prepared once D9 is set. A group ahead of schedule can fix its outline today, not before D8 and the eight-subsection note hold.

## ✓ Answer keys and assessment criteria

### Assessment criteria for the D8 submission

| Criterion                  | Insufficient                                     | Expected                                                      | Excellent                                                                  |
|----------------------------|--------------------------------------------------|---------------------------------------------------------------|----------------------------------------------------------------------------|
| Scope                      | Perimeter vague or inconsistent with the mapping | Four paragraphs, third-party test passed, interfaces declared | Same, with scope exclusions owned and dated                                |
| Traceability of inclusions | Controls included without justification          | Each inclusion traced to a register risk or a requirement     | Same, cross-consistency checked both ways, orphans handled                 |
| Management summary         | Absent or triumphalist                           | Ten honest lines: profile, work sites, expected decision      | Same, with the assessment's figures cited to good purpose                  |
| Strategy note              | A subsection copying D8                          | Half a page articulated with the sessions 2 and 7 subsections | Same, within the three to five pages, amendments justified in one sentence |

+10 XP

Leçon terminée

+200 XP

Formation terminée !